SMALL-TEAM SECURITY · PASSKEYS

PASSKEYS AT WORK

A Small-Team Guide to **Phishing-Resistant Logins**, **Device Changes** and **Account Recovery**

SYNCED VS DEVICE-BOUND | LOST PHONES | RECOVERY | 30-DAY PLAN

ZIRLANDIA MILKOVIC

SMALL-TEAM SECURITY · PASSKEYS

PASSKEYS AT WORK

A Small-Team Guide to Phishing-Resistant Logins, Device Changes and Account Recovery

ZIRLANDIA MILKOVIC

Passkeys at Work
A Small-Team Guide to Phishing-Resistant Logins, Device Changes and Account Recovery

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 12 November 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional. Product features and standards reflect the research cut-off date and should be checked against current documentation.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Phone in the Taxi 4
Who This Book Is For 6
How to Use This Book 7
The Ten-Minute Passkey Readiness Check 7

CHAPTERS

1. Why Passwords Keep Failing Small Teams 9
2. How Passkeys Work, in Plain English 14
3. Synced or Device-Bound: Choosing the Right Passkey 20
4. Rolling Passkeys Out Across Your Business Accounts 25
5. When an Employee Loses a Phone 31
6. Shared Devices, Shared Accounts and People Who Come and Go 36
7. Account Recovery Without Creating Security Weaknesses 43
8. Your 30-Day Passkey Rollout Plan 49

CLOSING

Conclusion: Passwordless Is a Process 53

APPENDICES

Appendix A: Account and Sign-In Inventory 55
Appendix B: One-Page Passkey Policy 56
Appendix C: Lost or Stolen Phone Runbook 57
Appendix D: Onboarding and Offboarding Checklists 59
Appendix E: Recovery Register and Helpdesk Script 60
Appendix F: 30-Day Rollout Tracker 62

BACK MATTER

Glossary 64
A Note on GDPRGard.eu 65
About the Author 66
Notes and Sources 67

Educational Disclaimer

This book is practical, educational guidance for small-business owners, freelancers and the people who look after their accounts and devices. It is not legal, security-engineering, data-protection or procurement advice, and it does not create a professional relationship between the author and the reader.

Passkeys are a fast-moving technology. Products rename features, move settings and change what they allow from one quarter to the next. The menus, labels and limits described here reflect the research cut-off date at the back of the book. Before you change how your business signs in, read your providers' current help pages, test on a small group first and ask a qualified adviser if your situation is regulated or unusual.

Following the steps in this book can make your accounts much harder to phish and much easier to recover. It cannot guarantee that nothing will ever go wrong, and no checklist can promise that a lost phone, a bad migration or a clever attacker will never cause trouble.

Every business, person and incident in a worked example is **fictional** and labelled as such. Real standards, products and statements are sourced in the notes at the back, together with an honest list of what the author could not verify.

Introduction: The Phone in the Taxi

Ines runs a six-person marketing agency in Porto. Last year she did the sensible thing and moved the team to passkeys on the main business accounts. No more passwords typed into lookalike pages, no more texted codes. People tapped a finger on a phone and they were in. For three months it felt like a small miracle.

Then her designer, Rui, left his phone in a taxi on the way to a client pitch.

Rui's phone was his passkey. It was also his authenticator app, his bank notification device, his email and the thing his Slack messages arrived on. His laptop had no passkey of its own, because setting one up had seemed unnecessary. It was nine in the morning, the pitch deck was in a shared drive he could no longer open, and Ines was reading a help page that began, *"If you have lost your only passkey device…"*

Nothing terrible happened. The phone was locked, the taxi firm found it by lunchtime, and the pitch was delayed by an hour. But the morning exposed three questions Ines could not answer:

1. **If a phone is lost, what exactly is lost?** The passkey? The account? The company's data?
2. **How does Rui get back in** without Ines becoming the easiest person in the world to impersonate?
3. **What had they actually decided,** and written down, about all of this before it happened?

That gap is what this book is about. Most passkey writing explains *why* passkeys are better than passwords, and they are. Far less explains how to **run** a workplace on them: which kind to choose, how to roll them out across a dozen business accounts, what to do about shared devices and shared logins, how to onboard and offboard people, and above all how to let someone back in without creating a weakness an attacker can use instead.

Passkeys remove a whole family of problems, notably the stolen password and the convincing fake login page.[1][2][3] They do not remove the need to think. Every authentication system is only as strong as the way it handles the day someone loses the thing they log in with. A business that adopts passkeys but leaves a weak recovery path open has not gone passwordless. It has moved its password somewhere less visible.

You will not be told to rip out your passwords tomorrow. The goal is smaller and more useful: **a workplace where signing in is quick and phishing-resistant, and where losing a device is a ten-minute inconvenience rather than an emergency.**

> **The rule.** A passkey rollout is finished when you have tested the recovery, not when the last person has registered. If you have never locked yourself out on purpose, you do not yet know what your plan does.

The book follows the shape of a rollout. Chapters 1 and 2 explain what is wrong with passwords for small teams and how passkeys actually work. Chapter 3 compares synced and device-bound passkeys and helps you choose between them. Chapter 4 walks through rolling passkeys out across your business accounts. Chapters 5, 6 and 7 deal with the three situations that decide whether it works in real life: a lost phone, shared devices and people joining or leaving, and account recovery. Chapter 8 gives you a 30-day plan. The appendices hold the checklists, a one-page policy and a lost-device runbook you can print.

Who This Book Is For

This book is written for people who run or look after the accounts of a small organisation but are not identity engineers:

- **Owners and managers of small businesses** with between one and about fifty people, in the EU or elsewhere.
- **Freelancers and consultants** whose entire working life sits behind a handful of logins.
- **Office managers, operations leads and the "accidental IT person"** who has been handed the admin console and told to keep everyone safe.
- **Bookkeepers, virtual assistants and agencies** who hold access to clients' accounts and want to do it safely.
- **Advisers**, such as accountants or IT freelancers, who are asked "should we switch to passkeys?"

You do not need technical knowledge. Where a term matters it is explained in plain language, and there is a glossary at the back. If you run a full identity team with dedicated tooling, the recovery, shared-account and lifecycle chapters may still be useful, but the engineering detail here is deliberately light.

A word on scope. The book covers **customer-side** passkey use for ordinary business services: email suites, cloud storage, accounting, banking portals, social media, domain registrars and the rest. It does not cover building passkey support into your own product, regulated payment authentication in depth, or high-security government use.

How to Use This Book

You can read the book in order, which gives the full story, or jump to what you need.

- **Short on time?** Do the Ten-Minute Readiness Check on the next page, then read Chapter 7 and print Appendix C.
- **About to start a rollout?** Read Chapters 3 and 4, then use Appendices A and B.
- **Someone just lost a phone?** Go straight to Chapter 5 and Appendix C.
- **Hiring or letting someone go?** Read Chapter 6 and use Appendix D.
- **Worried about recovery?** Read Chapter 7, then fill in Appendix E.

Three conventions help. A dark box headed **The rule** is the one idea to remember from a chapter. Checklists use empty boxes you can tick. Tables and worksheets are meant to be filled in, on paper or on screen.

Throughout the book, "account" means any login your business depends on, "authenticator" means the thing that proves you are you (a phone, a laptop, a security key), and "provider" means the company that runs the service you log in to. If a word is unfamiliar, check the glossary.

The Ten-Minute Passkey Readiness Check

Answer yes or no. Be honest; nobody is marking this.

1. Can you list every business account that matters, and who can sign in to each one?

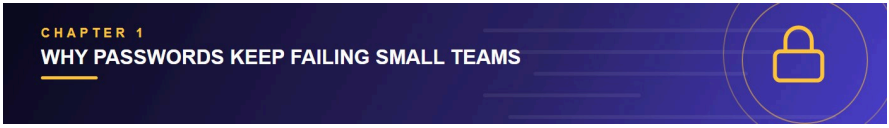
2. Does every person who can reach company data sign in with something stronger than a password alone?
3. Does anyone still receive sign-in codes by text message?
4. Does every important account have at least **two** ways to sign in that do not depend on the same phone?
5. Do you know what happens, step by step, when someone loses their phone?
6. Is there a written, tested way to let a locked-out person back in without relying on "I know them"?
7. Do any people share a login, or share a computer without separate user accounts?
8. Do you have two emergency administrator accounts whose access does not depend on a single employee?
9. When someone leaves, can you remove their access to every business account in one working day?
0. Have you ever tested a recovery, on purpose, before you needed it?

Scoring. Count your **no** answers to questions 1, 2, 4, 5, 6, 8, 9 and 10. Then add one for each **yes** to questions 3 and 7.

- **0 to 2:** strong position. Use the book to test and document what you have.
- **3 to 5:** typical. Chapters 5 to 7 contain several quick wins.
- **6 to 10:** worth a focused month. Go straight to Chapter 8 and Appendix F.

CHAPTER 1

Why Passwords Keep Failing Small Teams



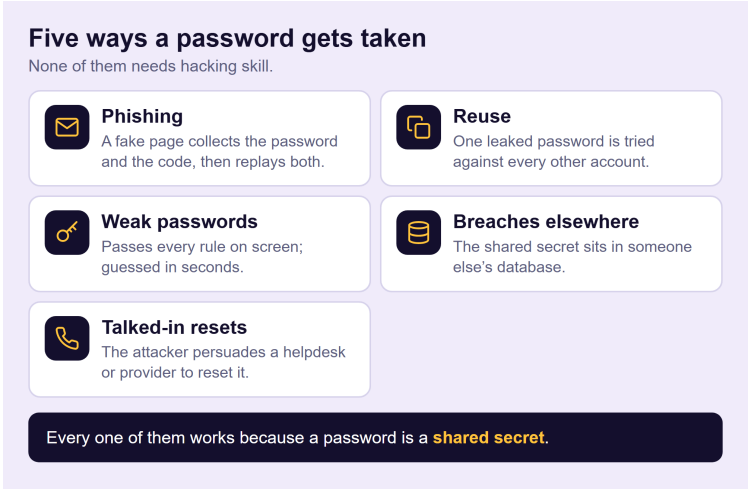
A single door, left slightly open: most small-business breaches start with a login, not with a clever hack

Ask a small-business owner what their biggest security risk is and you will hear about ransomware, hackers and viruses. Ask what an attacker actually needs to get in and the answer is usually far less dramatic: a username and a password, or something that proves you know them. This chapter explains why that arrangement fails small teams in particular, and what a passkey changes.

The password problem, honestly

A password is a **shared secret**. You know it, and so does the service you are logging in to, in some form. Anyone else who learns it can pretend to be you. Everything that goes wrong with passwords follows from that one fact.

Small teams feel it harder than large companies for a plain reason: they have the same number of accounts to protect and far fewer people to protect them. There is no security department. There is someone who "does the IT" between invoices.



Five ways a password gets taken, and why none of them needs any skill

1. Phishing. An email or message sends someone to a page that looks exactly like the real sign-in. They type their password, and often the code from their authenticator app as well. The attacker uses both on the real site within seconds. The employee did nothing unusual and nothing seemed wrong.

2. Reuse. People have dozens of accounts and one memory. A password leaked from a forgotten forum in 2019 is tried against their email today. Attackers automate this at scale; it is called credential stuffing.

3. Weak or guessable passwords. *Summer2026!* satisfies every rule on the screen and takes seconds to guess.

4. Breaches elsewhere. Even a perfect password is only as safe as the database it sits in. When a service is breached, the shared secret is exposed, and your only defence is to notice and change it.

5. Social engineering of the reset. An attacker who cannot get the password calls the helpdesk, or emails the provider, and talks their way into a reset. We return to this in Chapter 7, because it matters even more once you have passkeys.

Why "just add a code" is not enough

Most businesses already added a second step: a code by text message or from an authenticator app. That was a real improvement, and if you have it, keep it until something better is in place. But it has a limit that surprises people.

A code is still **something you type**. If a fake page asks for it, you can type it into the fake page. The attacker's tool passes it on to the real site in real time. That is why the US Cybersecurity and Infrastructure Security Agency, in its guidance on the subject, separates ordinary multi-factor authentication from **phishing-resistant** multi-factor authentication, and names FIDO/WebAuthn, the standard behind passkeys, as the main widely available option that qualifies.[3]

Text messages add their own weaknesses: phone numbers can be taken over by a fraudulent SIM swap, and messages can be intercepted or socially engineered away.

> **A useful test.** Imagine your most careful employee receives a perfect fake of your email sign-in page, on a rushed Friday. Does anything in your current set-up *stop* them from signing in to it? If the honest answer is "only their attention", you are depending on attention, and attention runs out.

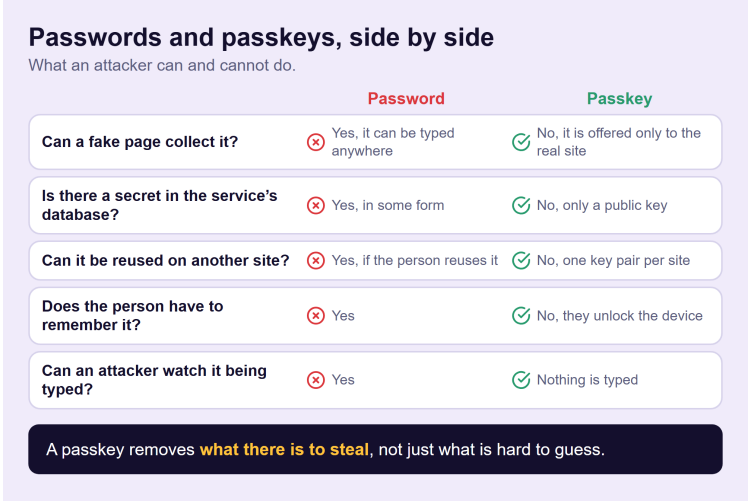
What a passkey changes

A **passkey** replaces the shared secret with a pair of cryptographic keys. One key, the **private** key, stays on your device and never leaves it in usable form. The other, the **public** key, is given to the service. To sign in, your device proves it holds the private key by signing a one-time challenge from the service. Nothing secret crosses the network, and nothing secret sits in the service's database for a thief to steal.[1][2]

Three consequences follow, and they are the whole reason to bother:

- **There is no password to phish.** A fake page has nothing to collect. The proof is also tied to the real website's address, so a lookalike domain simply cannot use it (Chapter 2 explains how).
- **There is nothing to reuse.** Each service gets its own key pair. A breach at one service does not hand anyone a key to another.

- **There is nothing to remember or type.** You unlock your device with a fingerprint, a face scan or a PIN, and you are signed in.



Passwords and passkeys side by side: what the attacker can steal, and what they cannot

The second-order benefit matters to small businesses at least as much as the security: **passkeys are quicker than passwords**. In an October 2025 benchmark from the FIDO Alliance, member companies reported far higher sign-in success with passkeys than with other methods (93 percent against 63 percent). The index is drawn from a small group of large organisations, so read it as a direction and not as a promise for your team.[4] But the direction is clear, and it is the opposite of what most people expect from "more secure".

What passkeys do not fix

Passkeys are not magic, and a book that sells them as magic would be doing you a disservice. Be clear about the limits from the start:

- **A signed-in session can still be stolen.** If malware on a computer steals the session after you have signed in, the attacker does not need your passkey.
- **A compromised device is a compromised device.** If an attacker controls the laptop you are unlocking, the passkey cannot protect you from what they do next.

- **Recovery can be the back door.** If a locked-out person can get back in with an emailed link or a text code, then an attacker can too, and the strong front door is wasted. Chapter 7 is entirely about this.
- **Not everything supports passkeys yet.** Some tools, especially older ones, will keep asking for a password for some time. You will run a mixed world for a while.
- **People still make mistakes.** A phished employee may approve the wrong request, hand over a recovery code or install the wrong thing.

Hold that list in your mind. Each item turns into a chapter or a checklist later in the book.

Why a small team can do this well

Large organisations often struggle with passkeys because they have thousands of people, decades of systems and complicated procurement. A small team has a real advantage: you can decide, you can roll out in weeks, and you know everyone's name.

You also have a good starting position. The big suites most small businesses run on, such as Google Workspace and Microsoft 365, both support passkeys, with administrator controls over how they are used.[5][6] Apple, Google and Microsoft's consumer platforms all sync passkeys between a person's devices, and the major password managers can store them too.[7]

> **The rule.** Adopt passkeys to remove what an attacker can steal, then design the recovery so it cannot be used to take it back.

Try it this week

- ☐ List the five accounts that would hurt most to lose: usually email, cloud files, banking, your domain registrar and accounting.
- ☐ Check which of the five already offer a passkey option. Look under security or sign-in settings.
- ☐ Note who can sign in to each, and how.
- ☐ Do not change anything yet. You will do that in Chapter 4.

CHAPTER 2

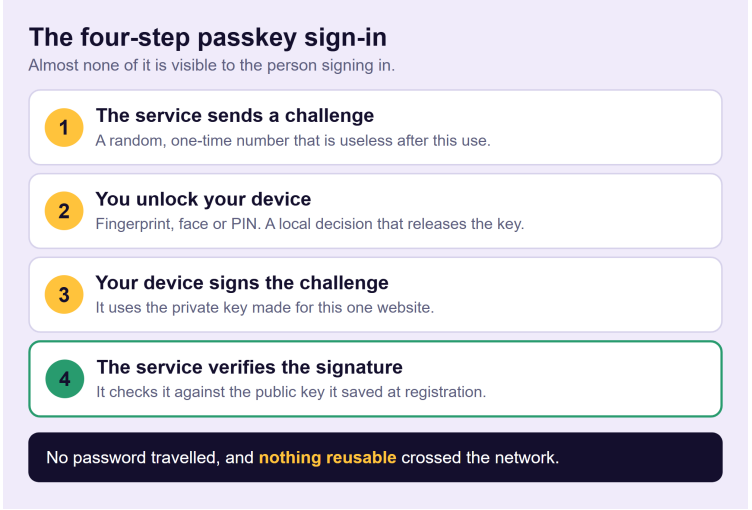
How Passkeys Work, in Plain English

A phone on a desk: the device is the key, and it unlocks locally

You do not need to understand cryptography to run a workplace on passkeys. You do need a mental model that is accurate enough to make good decisions, to explain the idea to your team without waving your hands, and to spot a marketing claim that does not hold up. This chapter gives you that model in a few minutes.

The four-step sign-in

Here is what happens when someone signs in with a passkey. Notice how little of it they see.



The four-step passkey sign-in: challenge, unlock, sign, verify

1. **The service sends a challenge.** It is a random, one-time number. The challenge is useless on its own and useless after this one use.
2. **You unlock your device.** A fingerprint, a face scan, or the device PIN. This happens on your device. The unlock is a local decision: it releases the private key for this one operation.
3. **Your device signs the challenge.** It uses the private key for **this website**, and sends the signature back.
4. **The service verifies it.** Using the public key it saved when you registered, the service checks the signature. If it matches, you are in.

There was no password. No secret travelled. If someone recorded the entire exchange, they would learn nothing they could use tomorrow, because tomorrow's challenge is different.

What lives where

It helps to be precise about what sits on each side.

	On your device	On the service
Private key	Yes, protected by your unlock	Never
Public key	Not needed	Yes, stored with your account

	On your device	On the service
Your fingerprint or face	Stays on the device, used only to unlock	Not sent, not stored
A shared secret	None	None

That last row is the one to remember. A breach at the service can leak public keys, which are useless to an attacker, and nothing that lets them sign in as you.

A point that often reassures people: in the passkey design, the fingerprint or face data is used by the device to decide whether to release the key. It is not sent to the website. For an employer thinking about data protection, that is a meaningful difference from an arrangement where the company would collect and store biometric data itself. It is still sensible to check how your own devices and providers describe this, and to offer a PIN to anyone who prefers it.[1] [8]

Why a fake site cannot use a real passkey

This is the clever part, and it is worth understanding because it explains the whole phishing claim.

When a passkey is created, it is tied to the **domain** of the website that asked for it, in the technical specification called the relying party identifier. Later, when your browser or phone is asked to sign in, it checks the address of the site it is actually talking to. If the address does not match the one the passkey was made for, the device simply **offers nothing**. There is no decision for the user to make and no way to be tricked into making the wrong one.[1]

Real address versus lookalike address: the passkey is only offered to the site it was made for

Compare that with a password. A password does not know where it is being typed. It cannot say "this is not the right site". A person has to notice, and they have to notice on the one day they are tired, rushed or distracted. With passkeys the check is moved from the person to the software, which does not get tired.

Passkeys, FIDO, WebAuthn: the jargon, decoded

You will meet a few acronyms. Here they are in one place:

- **FIDO Alliance.** An industry group that defines the standards behind passkeys. Its members include the big device and platform makers.
- **WebAuthn.** The web standard, published by the W3C, that lets a website ask a browser for a passkey sign-in.[1]
- **CTAP.** The protocol that lets a phone or a hardware security key talk to your computer to do the signing.
- **Passkey.** The user-friendly name for the credentials these standards produce. It is a *discoverable* credential, meaning your device can find the right one for a site without you typing a username first.
- **Security key.** A small physical device, often USB or NFC, that holds passkeys inside it and cannot be copied.

The standard does not belong to one company, which is a large part of why it has been adopted so widely.

Signing in on a computer without a passkey on it

A common worry: "My passkey is on my phone. What about when I am at a laptop that has none?" The standard answers this with a feature often called **cross-device sign-in**. The laptop shows a QR code; you scan it with your phone; the phone checks that it is physically close to the laptop over Bluetooth, asks you to unlock, and signs in. The key never leaves the phone, and the proximity check is there to stop someone far away from relaying the request.

For small teams this is quietly very useful. It means someone can sign in on a client's computer, an airport kiosk or a borrowed laptop without leaving anything behind. We will use it in Chapter 6 for shared machines.

Is it really passwordless?

Mostly, not entirely, and that honesty is part of running this well.

Many services keep a password as a **fallback** even after you create a passkey. Some let you remove it, some do not, and some are only able to do passkeys as a second step after a password. Your own business will run a mix: passkey-only on the accounts that allow it, passkey plus other methods on the rest, and a password manager holding the passwords that remain. That is fine. A realistic target is "passwords are rare, never typed from memory, and absent from the accounts that matter most".

Quick reference

Question	Short answer
Can a passkey be phished?	The sign-in cannot be handed to a fake site; other attacks still apply
Does the website store my fingerprint?	No; the device uses it locally to unlock
What if my phone is stolen?	The thief still has to unlock it; Chapter 5 covers the rest
Can I have more than one per account?	Often yes; and you should

Question	Short answer
Can I use it on a computer that is not mine?	Yes, using cross-device sign-in

The rule. A passkey is tied to a website, unlocked by you, and useless anywhere else. That is why you can stop asking people to be careful and start letting the software refuse.

CHAPTER 3

Synced or Device-Bound: Choosing the Right Passkey

Two physical security keys on a desk: a credential that cannot be copied

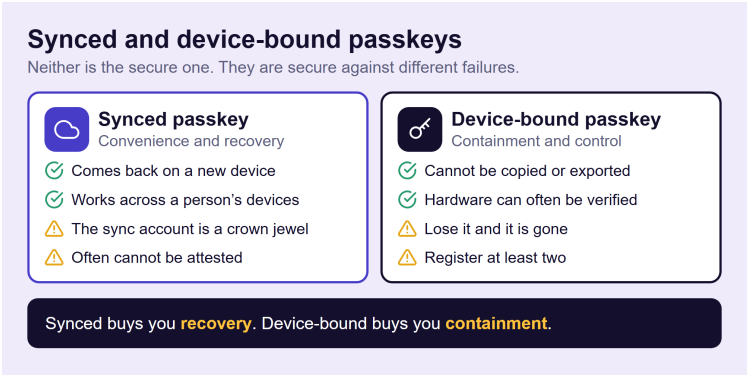
Not all passkeys behave the same, and the difference is the single most important design choice you will make. It decides what happens when a device is lost, who can access an account, and how much trust you place in a company's sync service. This chapter explains the two families and gives you a simple way to choose.

The two families

Synced passkeys are stored in a cloud account that belongs to a person or an organisation, and they are copied securely to every device signed in to that account. Apple, Google and Microsoft all offer this for their platforms, and several password managers do the same.[7] If a person loses a phone and buys a new one, signs back in and restores their account, the passkeys come back with it. That is a big part of why passkeys have become so convenient.

Device-bound passkeys live on one device, or one security key, and cannot be copied off. Hardware security keys are the classic example. Some computers also store passkeys in a protected chip, and in that

case the credential is bound to that machine. If you lose the device, you lose that credential. The upside is that nothing can be exported, synced or restored by anyone else.



Synced versus device-bound: convenience on one side, containment on the other

What you gain and give up

	Synced passkey	Device-bound passkey
Lost device	Restored on a new device via the sync account	Gone; you need another registered authenticator
Convenience	High; works across your devices	Lower; one device or key at a time
Who must you trust?	The sync account and its recovery	Only the device
Main risk	Whoever controls the sync account controls the passkeys	Lockout if you register only one
Best for	Everyday staff accounts	Administrators and sensitive roles
Can the company check the device type?	Usually not	Often yes, using attestation

The pattern is consistent: **synced buys you recovery, device-bound buys you containment.** Neither is "the secure one". They are secure in different ways, against different failures.

The sync account becomes a crown jewel

This is the point that is easy to miss. If your staff use synced passkeys, then the account that syncs them, an Apple account, a Google account, a Microsoft account or a password manager vault, is now protecting access to many other things. Its own sign-in and its own recovery decide how safe all of those are.

That is not a reason to avoid synced passkeys. For most staff accounts they are the right choice, because the alternative is a lockout every time someone upgrades a phone. It is a reason to **protect the sync account properly**: a strong sign-in of its own, device lock screens that are not trivial, and a recovery method you understand. Apple, for example, describes recovery of its keychain through a recovery contact or an escrow mechanism protected against brute-force attempts.[7] Whatever your platform, find out what it uses.

What attestation means for a business

When a passkey is created, the device can optionally include a statement about **what kind of authenticator it is**: a certain model of security key, say. This is called attestation. A business can use it to say "for administrators, only accept these approved security keys".

You do not need this for most staff. It becomes useful for the few accounts where you want to be sure of the hardware. Providers handle it differently, and some limit the checks to device-bound credentials. Microsoft's guidance, for instance, recommends device-bound passkeys for administrators and highly privileged users and synced ones for everyone else, and notes that synced passkeys have the security posture of unattested authenticators.[6] Treat that as a useful rule of thumb across providers, and check yours.

The standards view

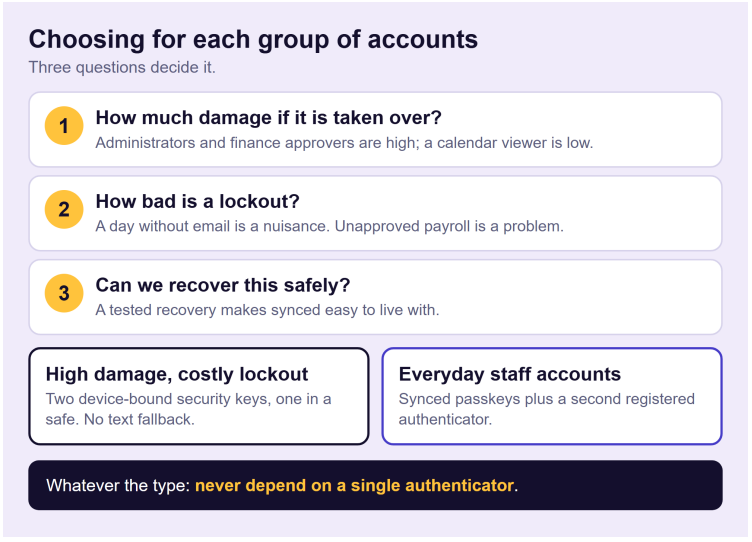
If you ever have to answer a regulator, an insurer or a client's security questionnaire, it helps to know what the formal guidance says. The US National Institute of Standards and Technology, in its 2025 revision of its digital identity guidelines, allows syncable authenticators such as passkeys to be used at its second assurance level, with conditions about how the syncing is protected, but does not allow them at its

highest level because a private key that can be synced is a key that can be exported.[9] Hardware-bound credentials remain the route for the highest-assurance cases.

You are unlikely to need NIST's top level. But the logic carries over to a small business in a simple form: **the more damage one account can do, the more you should lean towards device-bound credentials for it.**

A simple way to choose

Use three questions for each group of accounts.



A decision path for each group of accounts: synced for staff, device-bound for administrators

1. **How much damage could this account do if an attacker took it over?** An administrator who can reset everyone else's login is a very different risk from someone who can only read a project calendar.
2. **How bad is a lockout?** A person who cannot get into their email for a day is a nuisance. A finance approver who cannot approve payroll is a problem.
3. **Can we recover safely?** If you have a tested recovery for this account, a synced passkey is easy to live with. If you do not, a device-bound passkey plus a second one in the safe is easier to reason about.

A practical default for a small business looks like this:

- **Administrators and finance approvers:** two device-bound security keys each, one kept in a safe place, in addition to any phone passkey if the platform allows both.
- **Everyday staff:** synced passkeys through the platform's own account, with a second registered authenticator.
- **Contractors, interns, visitors:** cross-device sign-in or a time-limited setup, never a shared login.
- **Emergency (break-glass) accounts:** device-bound, offline and documented (Chapter 7).

Two is the minimum

Whichever type you choose, the rule is simple and worth printing: **nobody should depend on a single authenticator for an account that matters.** A person with a passkey on one phone and nothing else is one dropped phone away from calling you. A person with a passkey on a phone and another on a laptop, or a security key in a drawer, is a minor inconvenience away from a new phone.

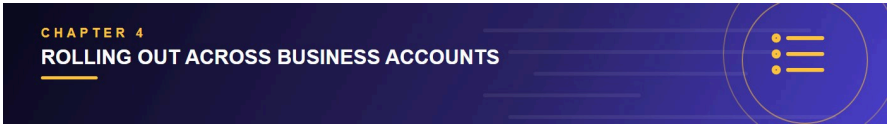
> **The rule.** Choose synced for convenience and device-bound for containment, then register at least two of something, so that no single loss locks anyone out.

Worked example (fictional)

Ines, from the introduction, reviews her own team after the taxi incident. Rui, the designer, had one synced passkey on his phone. Her fix has three parts: every person adds a second passkey on a laptop; Ines and her operations manager each get two hardware security keys for the admin console, one carried and one in the office safe; and she writes a one-page rule that says who may reset whom. The whole change takes an afternoon and costs two or three small purchases. The risk of a repeat of the taxi morning falls from a crisis to a short phone call.

CHAPTER 4

Rolling Passkeys Out Across Your Business Accounts



A tidy desk with a closed laptop and a lamp: a calm rollout is a boring rollout

The most common way a passkey rollout goes wrong is not a technical failure. It is an announcement ("from Monday we are all passwordless") followed by a week of confusion, three lockouts and a quiet return to old habits. This chapter gives you an order of work that avoids all that: inventory, tier, pilot, enrol, tighten.

Step 1: Know what you are protecting

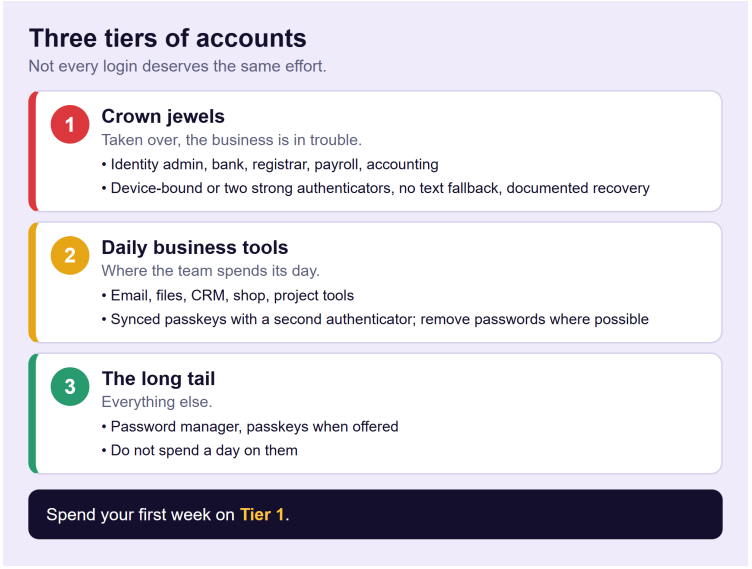
You cannot roll passkeys out across accounts you have not listed. Spend an hour, not a week, on an inventory. Appendix A is a worksheet for it. For each account note:

- the **service** and the address people sign in at;
- **who** can sign in, including former staff and contractors;
- **how** they sign in today: password, text code, app code, passkey, single sign-on;
- whether the service **supports passkeys** and whether it supports **more than one** per account;
- what would happen if an attacker took it over.

Do not forget the unglamorous ones: the domain registrar, the website host, the accounting package, the payroll portal, the business bank, the social accounts, the advertising accounts and the app-store developer account. Attackers love these precisely because owners forget them.

Step 2: Sort into three tiers

Not every account deserves the same effort. A three-tier sort stops you from treating the office coffee-machine app like the company bank.



Three tiers of accounts, and what each one gets

Tier 1: crown jewels. Accounts that can ruin the business if taken: the main identity account (Google Workspace or Microsoft 365 admin), the business bank, the domain registrar, the password manager's admin, accounting and payroll. These get **device-bound or at least two strong authenticators, no text-message fallback, and a documented recovery**.

Tier 2: daily business tools. Email, cloud files, project tools, CRM, the shop and the website's admin. These get **synced passkeys with a second authenticator registered**, and passwords removed where the service allows it.

Tier 3: the long tail. Everything else. Use a password manager for these, turn on passkeys when they are offered, and do not spend a day on them.

Step 3: Start with the identity provider

If your team uses a suite such as Google Workspace or Microsoft 365, that account is the **key to the rest**. Many other services sign in through it, and your email is also how most resets are sent. So it comes first.

Both suites let an administrator control how passkeys are used. In Google Workspace, an administrator can allow users to skip passwords with a passkey. The setting is off by default, and even when it is off people can still register passkeys as a second step or for recovery; Google has also said it added controls to audit enrolment and to restrict passkeys to physical security keys.[5] In Microsoft Entra ID, administrators use passkey profiles to decide whether a group may register device-bound passkeys, synced passkeys, or both, and Microsoft recommends device-bound for privileged users and synced for everyone else.[6]

Whatever you use, apply four habits:

1. **Pilot first.** Choose two or three people, including one sceptic and one non-technical person. If it works for them, it will work for the rest.
2. **Enrol administrators first, and with two keys.** Do not make the people holding the master keys the last to be protected.
3. **Keep a fallback during the pilot,** then remove it deliberately (Step 6).
4. **Write down the exact settings you chose,** so the next administrator does not have to guess.

Step 4: Add the password manager

A good team password manager is not an alternative to passkeys; it is part of the same plan. It holds the passwords that survive the transition, stores recovery codes, shares access to the few genuinely shared accounts, and, in several products, stores passkeys too.[7]

Decide early whether your passkeys will live in the **platform** (Apple, Google, Microsoft) or in the **password manager**. Pick one place per person for work accounts, and write it down. A person with half their passkeys in one place and half in another, and no record of which, is a recovery problem waiting for a bad day.

Step 5: Enrol people the humane way

A rollout is a small change-management project, and people judge it by whether Monday morning goes well.

- **Explain it in one minute.** "We are replacing passwords with your phone or laptop unlock. You cannot be tricked into giving it to a fake page."
- **Do it together, in person or on a video call.** Fifteen minutes per person is plenty. Have them register a passkey on their phone **and** a second one, on a laptop or a security key.
- **Make the second authenticator part of the same session.** If it is "we will do it later", it will not be done.
- **Test it before you leave.** Have them sign out, then sign in again with each authenticator.
- **Show them what a lost phone looks like.** One slide: who they call, what happens next. Chapter 5 has it.

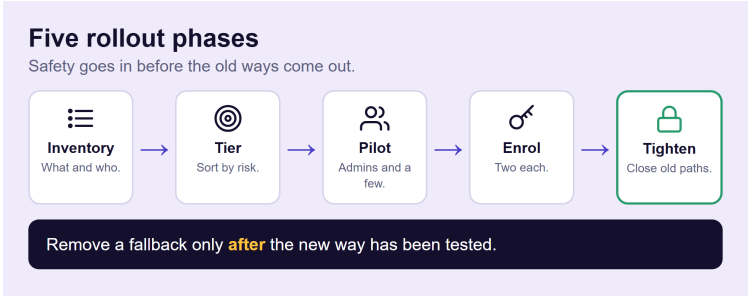
Offer a **PIN instead of biometrics** to anyone who prefers it. Some people are uncomfortable with fingerprint or face unlock on a work device, and the passkey standard does not require biometrics.

Step 6: Tighten, deliberately

Passkeys only deliver their full benefit once the weaker paths are closed. Do this in a sensible order, not all at once:

1. **Turn on passkey-only sign-in** for pilot users, then everyone, where your provider allows it.
2. **Remove text-message codes** for Tier 1 accounts first.
3. **Remove or randomise the password** on accounts that no longer need it, and keep it in the password manager.
4. **Review sign-in methods monthly** for the first quarter. Look for people who still use the old way. Ask why.

5. **Tell people what is happening before you remove a path**, not after.



Five rollout phases, from inventory to tightening

What to measure

A rollout without numbers drifts. Track four simple ones, in a spreadsheet:

Measure	Why it matters	A sensible target
Staff with at least two authenticators	Shows lockout risk	100 percent of Tier 1, 90 percent of everyone else
Accounts that allow passkeys and have them on	Shows coverage	Rising each month
Sign-ins that still use passwords or texts	Shows the fallback you have not closed	Falling toward zero for Tier 1
Helpdesk requests about sign-in	Shows whether people are coping	A short spike, then lower than before

When something does not support passkeys

Some services will keep asking for a password for a long time. Do not let them drag the plan down.

- **Use the password manager** to generate a long unique password and store it.
- **Turn on the strongest second step the service offers**, preferably a security key or an authenticator app, rather than text.
- **Put it in Tier 2 or 3 and move on.**
- **Check back every six months;** support arrives quickly now.
- **If it is Tier 1 and does not support anything strong,** treat that as a supplier-risk question and ask them about it in writing.

Roll back safely

Plan a way back for the pilot. If a group of people cannot make it work, you should be able to restore their old method for a week without embarrassment or drama. Quietly reverting an account to a password and a code is not a failure. Leaving people locked out is.

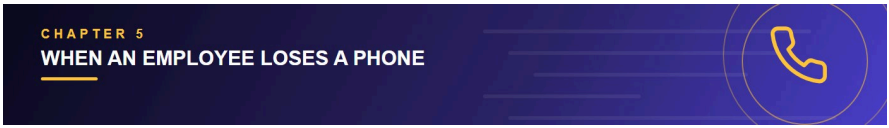
> **The rule.** Roll out in this order: identity first, administrators first, two authenticators for everyone, and remove the old ways only after the new ones have been tested.

Worked example (fictional)

Luka, a freelance translator in Zagreb, has eleven accounts that matter. He puts his email, his bank and his domain registrar in Tier 1, adds a hardware key for each (two keys, one in a drawer), and registers a phone passkey as well. His invoicing tool and cloud folder go into Tier 2 with synced passkeys. The rest go into a password manager. He spends a Saturday morning on all of it and writes the choices on one page. It is the least dramatic change he has ever made and the one he is most relieved by.

CHAPTER 5

When an Employee Loses a Phone



A café table at dusk: what you do in the first hour decides how much a lost phone matters

Every business will eventually have this call: "I have lost my phone." How you answer it, in the next hour, decides whether it is a minor inconvenience or a security incident. With passkeys the answer is, thankfully, usually calmer than it was with passwords. But only if you have done the thinking in advance.

What is actually lost

Start with the facts, because the first reaction is often panic.

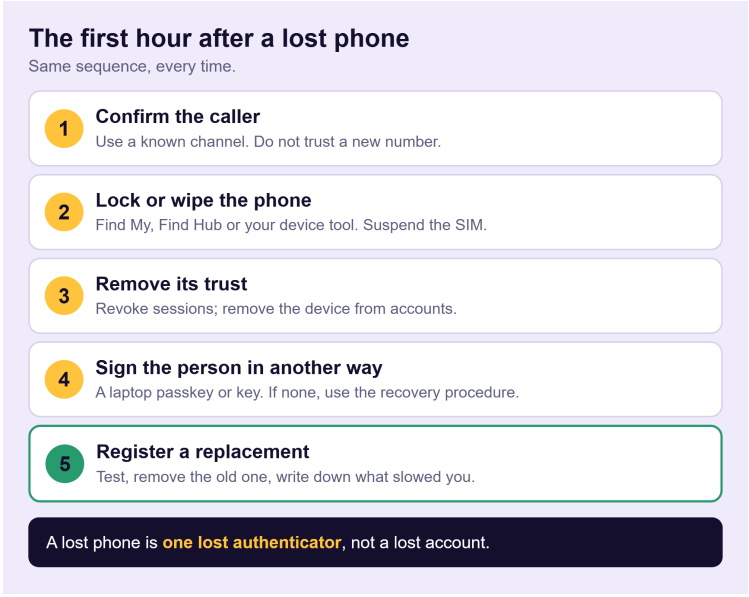
- **The phone is locked.** A phone with a PIN or biometric lock does not hand a thief the passkeys on it. They would have to unlock it first.
- **The passkeys on it are not usable without that unlock.** The private key is protected by the device and released only when its owner verifies.
- **Some risk remains.** If the phone had no lock, a weak PIN that was seen, or was left unlocked, then risk rises sharply. A phone that is also logged in to email, chat and the authenticator app is a rich target.
- **The accounts themselves are not gone.** The passkeys are credentials for the accounts. If the person has another authenticator, or the passkeys sync to a new device, they can sign

back in.

So the right mental model is not "the account is lost". It is "one authenticator is lost, and we must make sure it cannot be used and the person can sign in again".

The first hour

Use the same sequence every time. Print it (Appendix C) and put it where the helper will find it.



The first hour after a lost phone: five steps, in this order

Minutes 0 to 10: confirm and contain

1. **Confirm who is calling,** through a channel you already trust. If they are phoning from a new number, call their known one, or confirm through a colleague. This is the first moment an impersonator might try to exploit.
2. **Lock or wipe the phone remotely.** Use the device's own tracking feature (Apple's Find My, Google's Find Hub, or your device-management tool if you have one). Lock it first; wipe it if recovery is unlikely.

3. **Put the SIM on hold** with the mobile network if the number is used for any codes. This reduces the risk of a text-code attack and SIM misuse.

Minutes 10 to 30: remove the phone's trust

4. **Sign the phone out of the person's accounts.** In the identity provider's admin console, revoke active sessions and remove the lost device from the person's list of authenticators. In the platform account (Apple, Google, Microsoft), remove the device from the account.
5. **Treat anything that was only on that phone as exposed:** authenticator-app codes, saved messages, any app that stayed signed in. Reset or re-enrol the ones that matter.

Minutes 30 to 60: get the person working again

6. **Check they have a second authenticator.** If they do (a laptop passkey, a security key), they can sign in and register a new phone. This is why Chapter 3 insisted on two.
7. **If they do not, use the recovery procedure** in Chapter 7: an administrator-issued, time-limited enrolment code after proper identity checks, never an emailed link or a casual "that sounds like you".
8. **Register the new phone,** test, and delete the old one from the list.

The decision that matters: how quickly to cut access

There is a tension in the first hour. Cut access too slowly and a thief may have time; cut it too aggressively and you disrupt someone who has simply left the phone at home. Use this rule:

Situation	Action
Phone misplaced, locked, found within the hour	Lock remotely; leave accounts as they are; confirm and carry on
Phone lost, locked, not found	Remove it from accounts; replace; review sign-in history
Phone stolen, or unlocked when lost	Treat as an incident: revoke sessions, reset exposed accounts, check for unusual activity, tell whoever handles data protection

Situation	Action
Phone lost by an administrator or finance approver	Treat as an incident by default, whatever the lock status

What about the passkeys on it?

For synced passkeys, the passkeys are also on the person's account and their other devices, so removing the lost phone from the account stops it from taking part in future syncing. The credentials stored on the device itself remain on that physical device, which is why remote wipe and the screen lock matter.

For device-bound passkeys, the credential exists only on that phone or key. The practical step is to **remove it from the accounts it was registered on**, so that if someone ever got past the lock they could not use it. Where the provider lets you list and delete registered authenticators, do that.

This is where your inventory pays off. If you know which accounts the person used and which authenticators they registered, removal takes minutes. If you do not, you are searching blind.

Personal phones used for work

Many small businesses rely on staff's own phones. That is understandable and workable, but it changes the lost-phone rules in two ways.

- **You cannot wipe a personal phone** without the owner's consent, and should not try. Your rights are over the **work accounts**, not the device.
- **Privacy applies.** Avoid asking for the phone's location or contents. Keep the response focused on accounts: remove its trust and re-enrol a new device.

Where practical, use the platform's work-profile feature so that business apps and credentials sit in a separate space that can be removed without touching personal data. Make the expectations part of the staff policy in Appendix B, and tell people before an incident what you will and will not do.

After the incident

A lost phone is a free fire drill. Within a week:

- ☐ Write down what happened, minute by minute, and where it slowed.
- ☐ Check whether the person had two authenticators. If not, make that the rule.
- ☐ Review sign-in logs for the lost device and for unusual activity around the time.
- ☐ Decide whether the event touched personal data and needs recording or reporting under your data-protection process.
- ☐ Update the runbook with whatever surprised you.

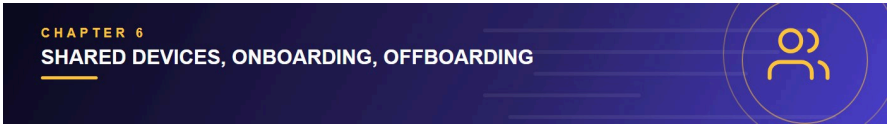
> **The rule.** Treat a lost phone as the loss of one authenticator, not of the account: lock it, remove its trust, sign the person in another way and register a replacement.

Worked example (fictional)

Back in Porto, Rui's taxi phone had a six-digit PIN and no recent sign-ins from new places. Ines used the new runbook. She called him on his office line, confirmed it was him, and locked the phone remotely from his account. He had a passkey on his laptop by then, so he signed in at the client's reception and registered a replacement phone that afternoon. The taxi firm returned the phone the next day. Total disruption: forty minutes, and no password reset for anyone.

CHAPTER 6

Shared Devices, Shared Accounts and People Who Come and Go

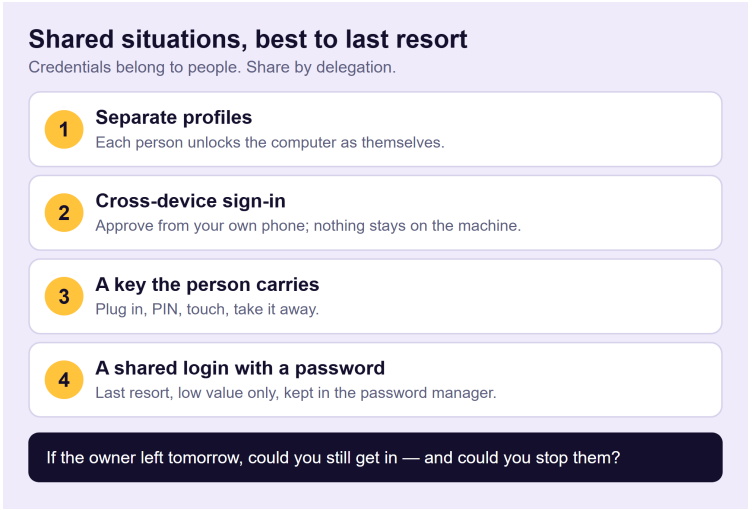


A reception desk shared by several people: passkeys belong to a person, not to a counter

Passkeys are designed around a person with a device. Small businesses are not. They have a front-desk laptop, a studio iPad, a social account run by three people, a bookkeeper who works for five clients and a summer intern. This chapter is about the awkward cases: devices that several people use, logins that several people share, and the arrival and departure of people.

The principle: credentials belong to people

A passkey proves that a particular person unlocked a particular device. That is its strength. It is also why it fits poorly when the "person" is a team and the "device" is a shared tablet. The cure is not to bend passkeys until they fit. It is to **shift the arrangement so that each person has their own identity, and shared things are handled by delegation.**



Four ways to handle shared situations, from best to last resort

Shared computers

If several people use one computer, such as a reception laptop, a workshop PC or a till, the options in order of preference are:

1. **Separate user profiles for each person.** Each person unlocks the computer as themselves, and each person's passkeys live in their own profile or account. This is the cleanest option and costs nothing.
2. **Cross-device sign-in.** The computer shows a QR code, the person approves it from their own phone, and nothing is left on the shared machine. This works well for borrowed or kiosk-style computers.
3. **A hardware security key the person carries.** They plug it in, enter its PIN and touch it. The key goes back in their pocket.
4. **A generic shared login with a password.** Last resort. If you must, keep it to low-value tasks, make it a long unique password in the password manager and never use it for the identity provider, banking or email.

Avoid registering a personal passkey on a computer that someone else can sign in to. If the machine's own login is shared, the passkey is effectively shared with it.

Shared accounts

Some accounts are used by more than one person: the company social media page, the ad account, the domain registrar, the supplier portal that only allows one login. The first question is whether it really has to be shared.

- **Prefer delegation.** Most business platforms let you add additional named users or roles. Social and advertising platforms generally allow several people to manage a page under their own accounts. Do that instead of sharing a login.
- **Where sharing is unavoidable,** keep the credentials in the team password manager, grant access to named people, and record who has it.
- **Check whether the service supports several passkeys on one account.** Many do. Register one per responsible person or one on each of two hardware keys, whichever the service allows.
- **Put an owner on every shared account.** Someone is responsible for removing people when they leave. Appendix A has a column for it.
- **Protect the account's recovery,** because it is the part nobody thinks about (Chapter 7).

> **A useful test.** For each shared account, ask: if the person who set it up left tomorrow, could we still get in, and could we stop them from getting in? If either answer is "I am not sure", the account has no real owner.

Bring your own device

Personal phones and laptops add privacy complications on top of security ones.

- **Separate work from personal** where the platform allows it: a work profile on Android, a managed or user-enrolled arrangement on Apple devices, a separate user account on a laptop.
- **Do not collect more than you need.** You are entitled to manage work accounts and their access, not to see a person's photos, messages or location.

- **Agree the basics in writing:** a screen lock is required, the operating system must be kept up to date, a lost phone must be reported at once, and the business may remove access to work accounts when a person leaves.
- **Offer an alternative.** If someone does not want to use a personal phone for work, a small low-cost work phone or a hardware security key avoids the argument.

Hardware security keys: who needs one

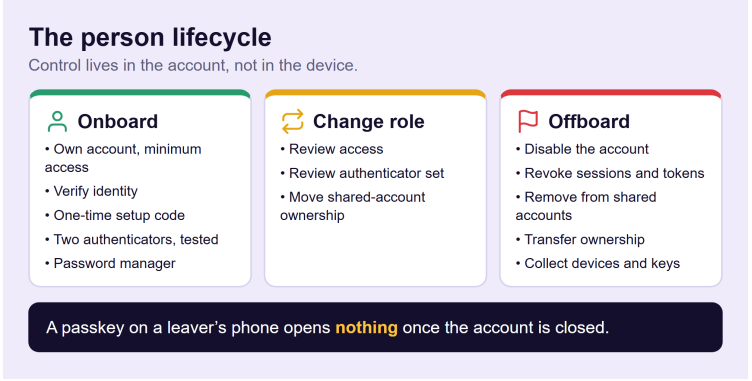
For many small teams, hardware keys are overkill for everyone. For a few people they are exactly right.

Role	Suggested set-up
Owner / super administrator	Two keys, plus a phone passkey if allowed; spare in a safe
Finance approver	Two keys or key plus laptop passkey
IT lead or accidental IT person	Two keys; emergency account keys in the safe
Everyday staff	Phone passkey and a laptop passkey; key optional
Contractors and visitors	Cross-device sign-in or a time-limited setup

Typical keys cost tens of euros each, so a pair per administrator is a modest budget. Check which sign-in protocols a key supports, and prefer a model that supports a PIN as well as touch, so a stolen key is not enough by itself.

Joining: the first day

Onboarding is the best moment to build good habits, because nothing has been learned wrongly yet.



The person lifecycle: onboard, change, offboard

Before day one

- ☐ Create the person's own account, with the minimum access for the role.
- ☐ Prepare a time-limited enrolment method, such as a one-time setup code issued by an administrator (many identity systems call this a temporary access pass or setup code), so the person never has to be given a password.[6]
- ☐ Choose a device: company-owned, or personal with a work profile.

On day one

- ☐ Verify identity in person or on a video call before issuing the setup code.
- ☐ Have them register two authenticators in the same session: for example, a phone passkey and a laptop passkey or a key.
- ☐ Test sign-in with each, then sign out and in again.
- ☐ Add them to the password manager and to only the shared accounts they need.
- ☐ Walk through the lost-phone one-pager.
- ☐ Record the authenticators and the date in the inventory.

Changing roles

People move, and the old access stays unless somebody removes it. At each change of role, review which accounts the person can reach, which shared accounts they own and whether their authenticator set

still matches the risk of the new role. A person promoted to finance approver may need a hardware key they did not need before.

Leaving: the day it ends

Offboarding is where small businesses leak, because it is rushed, emotional and spread across a dozen tools. Passkeys help here in an important way, because **control lives in the account, not in the person's device.**

When someone leaves, their personal phone may still hold a passkey for the company's email. That does not matter, provided you **disable or remove the account itself.** A passkey is a way of proving who you are to an account; if the account is closed or the person's access is removed, the passkey opens nothing.

Do this in one sitting, using a checklist (Appendix D):

- ☐ Disable the person's account in the identity provider; do not just remove the passkey.
- ☐ Revoke active sessions and app passwords, and remove any tokens that keep third-party apps signed in.
- ☐ Remove the person from shared accounts and change any shared password they knew.
- ☐ Transfer ownership of files, calendars, mailing lists and any account they owned.
- ☐ Remove their registered authenticators from any account where they are individually listed.
- ☐ Take back company hardware, including any security keys the business issued.
- ☐ Remove them from the password manager and rotate any shared secret they could see.
- ☐ Redirect their email for a period and record it, under your retention rules.
- ☐ Record the date and what was done.

Do the **urgent** items within minutes if the departure is hostile, and the rest the same working day.

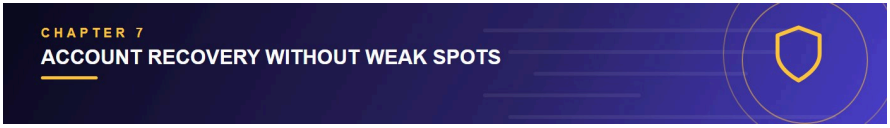
> **The rule.** Give every person their own identity, handle shared things by delegation, and when someone leaves, close the account, not just the device.

Worked example (fictional)

Ines's agency hires a summer intern, Mara. Before she arrives, Ines creates her account and a setup code that expires in a day. On Monday, over a ten-minute video call, she confirms Mara's identity, Mara registers a passkey on her phone and a second on the agency's loan laptop, and Ines adds her to two shared project folders and nothing else. In September Mara leaves. Ines disables the account, removes her from the folders and takes back the laptop. Mara's phone still holds a passkey, and it opens nothing.

CHAPTER 7

Account Recovery Without Creating Security Weaknesses



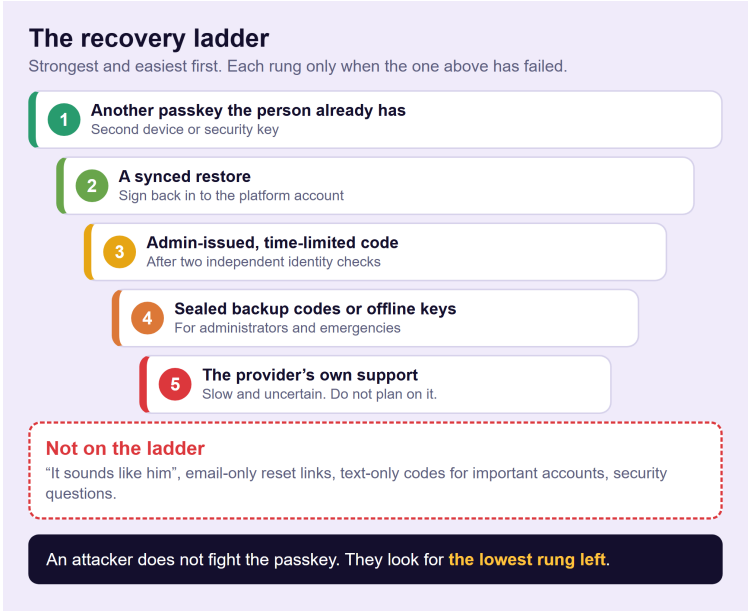
A small safe, door ajar: recovery is where the strong door meets the human one

This is the chapter that decides whether your passkeys are as strong as they look. A passkey makes the front door extremely difficult to force. A recovery process is a **second door**, and attackers always check it. If it opens with a text message, a convincing phone call or an email sent to an old address, then all the cleverness of the front door is wasted.

The weakest link rule

Security people have a simple way to say this: **an account is only as strong as the easiest way into it.** Every method that can get a person back in is a way an attacker can try to get in. Count them all: passwords that still work, text codes, emailed reset links, backup codes, helpdesk resets, "recovery contacts", old devices.

This is sometimes called a **downgrade attack**. The attacker does not fight the passkey. They click "I cannot use my passkey" and pick the weakest option left. If that option is a text code, they have turned your phishing-resistant sign-in into a text-code sign-in.



A recovery ladder: from strongest and easiest, to last resort

The recovery ladder

Design recovery as a ladder, with the strongest method first and each rung used only when the one above has failed.

Rung 1: another passkey the person already has. A second device, a laptop passkey, a security key. This is the answer most of the time, and is why Chapter 3 said "two is the minimum".

Rung 2: a synced restore. If passkeys are synced, signing back in to the platform account on a new device restores them. The platform account's own recovery then becomes important, as Chapter 3 explained. Apple, for instance, describes a recovery contact and an escrow mechanism for its keychain.[7]

Rung 3: an administrator-issued, time-limited enrolment code, after identity verification by two independent routes. This is the main recovery method for staff in a small business.

Rung 4: sealed backup codes or an offline key, kept in a safe by named people. This is for administrators and emergencies.

Rung 5: the provider's own support. Slow, uncertain and deliberately hard. Do not plan on it.

What is **not** on the ladder: casual verification ("it sounds like him"), email-only reset links, text-only codes for important accounts, and security questions. Remove them where you can.

Verifying identity when someone has lost everything

The hardest moment is when a person has no working authenticator and asks to be let back in. This is exactly the situation an impersonator would create, so the procedure must be more than "ask them a question about the office".

Use **two independent checks** from this list, and write the choices down in advance:

- A call back on a **known** number recorded before the incident, not the one calling.
- A video call where you recognise the person, with a second person present.
- Confirmation from the person's **manager** through a separate channel.
- An in-person visit, for local teams.
- For remote contractors, a pre-arranged shared phrase agreed in the onboarding session.

Avoid verification that relies on information an attacker could find on social media: birthdays, pet names, addresses.

Then apply **friction on purpose**:

- **A short delay** before a high-privilege recovery takes effect, with a notification to the person's other contact addresses and to a second administrator.
- **A two-person rule** for administrators and finance approvers: no one recovers their own account, and no single administrator approves a recovery alone.
- **A short-lived code** that expires within hours and works once.
- **A log:** who asked, who verified, which checks, what was issued.

Microsoft describes the same idea in its own tools, with a temporary pass used to register a new passkey and, for some cases, verified identity checks to recover an account; the details vary by product and version, so check the current guidance for yours.[6]

The helpdesk is the target

The most reliable way to bypass a strong sign-in is to persuade a person with power to turn it off. Several well-publicised attacks on large organisations have used this method, with an attacker impersonating an employee to an IT helpdesk and asking for a reset or new authentication method. The lesson for a small business is the same as for a large one: **the person who can reset access must not be able to be talked into it.**

Practical rules:

- **No resets by email or chat alone.** A message can be forged.
- **No urgency exceptions.** "I am about to board a flight and the client is waiting" is the exact story an attacker tells. The procedure applies to everyone, including the owner.
- **Give the helper a script** (Appendix E), so they do not have to improvise under pressure.
- **Make it acceptable to say no.** Tell the team, in writing, that anyone who follows the procedure and is told off for it will be backed up.

Emergency access: the break-glass accounts

Every business should have at least **two emergency administrator accounts** that are not tied to any single employee. Their purpose is to get you back in when normal access has failed: the owner is on a plane, the only administrator has left, or the identity provider has a configuration problem.

- **Make them long-lived and unlikely to be used.** Name them neutrally and keep them out of everyday work.
- **Protect them with device-bound security keys,** stored in two physically separate secure places, such as a safe and a bank box.
- **Record their use as an event.** Any sign-in should trigger an alert to at least two people.

- **Test them twice a year,** then lock them away again.
- **Write down who may authorise their use,** and nobody else.

Microsoft's guidance on emergency access accounts, and Google's advice to keep more than one super administrator, make the same point: a business needs a way back in that does not depend on one person's phone.[5][6]

Backup codes and seals

Some services give one-time backup codes. They are useful and they are also a classic weakness, because people screenshot them to a shared folder.

- Store them in the **password manager or a sealed envelope in a safe,** not in email or a general drive.
- Record **where** they are, not what they are.
- Replace them **after use** and after any staff change that could have exposed them.

Recovery for the sync account

Remember the crown jewel from Chapter 3. If staff use synced passkeys, the recovery of **their platform accounts** matters as much as the business accounts. For each person ask: what is the recovery path for their Apple, Google or Microsoft account, and does it depend on a phone number or email address that could be taken over? Encourage people to register a second authenticator and a recovery contact on their personal platform account too, where that is offered, and not to use a business mailbox as the only recovery address for a personal account.

Test it, on purpose

A recovery plan you have not tested is a story. Do this once a quarter:

- ☐ Pick a volunteer. Have them lock themselves out, using only a spare device.
- ☐ Run the full procedure. Time it.

- ☐ Try one **fake** request: have a colleague call the helper pretending to be the volunteer, and see whether the verification holds.
- ☐ Record what failed and fix it.

> **The rule.** Make recovery harder than signing in, but never impossible: layered, logged, slower for powerful accounts and with no step an impersonator can complete by sounding convincing.

Worked example (fictional)

Luka, the translator in Zagreb, loses his only phone and his laptop in the same bag. He has none of his usual authenticators. His registrar account has two security keys; the spare is in a drawer at home, and he reaches it by train. His email provider has a recovery rung he set up months ago: a trusted contact, his business partner Ana, who can confirm him through a call-back to his known number. The process takes a morning, which is exactly as intended: slow enough to stop a stranger, quick enough to get him back before the invoice deadline.

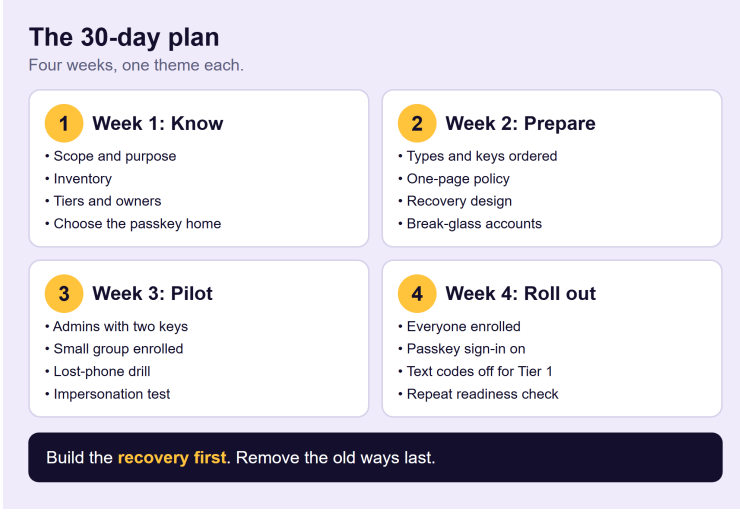
CHAPTER 8

Your 30-Day Passkey Rollout Plan

A bridge across calm water: thirty days from passwords to a workplace that can handle a bad day

You now have the ideas. This chapter turns them into a month of small, ordered tasks that a busy person can do in an hour or two at a time. The order matters: you build safety before you remove the old ways in.

The shape of the month



The 30-day plan: four weeks, each with one theme

Week	Theme	What you finish
1	Know	Inventory, tiers, owners, the choice of passkey home
2	Prepare	Policy, recovery design, emergency accounts, keys ordered
3	Pilot	Administrators and a small group enrolled, recovery tested
4	Roll out and tighten	Everyone enrolled, fallbacks removed where safe, drill done

Week 1: Know

Day 1: Decide the scope. Which accounts are in? Who is responsible? Write down one sentence of purpose: *"We will make signing in phishing-resistant and recoverable for every business account that matters."*

Day 2: Inventory. Fill in Appendix A. One hour; do not aim for perfection.

Day 3: Tier the accounts. Mark each Tier 1, 2 or 3 (Chapter 4).

Day 4: Name owners. Every account gets a person who is responsible for it, and a deputy.

Day 5: Choose the passkey home. Platform or password manager, per person. Write it down.

Week 2: Prepare

Day 8: Decide the types. Synced or device-bound by group (Chapter 3). Order hardware keys now: at least two for each Tier 1 administrator, plus spares, since delivery takes days.

Day 9: Draft the policy. Use Appendix B as a start. One page.

Day 10: Design recovery. Fill in Appendix E, choose your two identity checks, name the second approver.

Day 11: Set up emergency accounts. Two break-glass accounts, device-bound, stored apart (Chapter 7).

Day 12: Prepare the lost-phone runbook. Adapt Appendix C and add the real phone numbers and names.

Week 3: Pilot

Day 15: Enrol administrators first, with two authenticators each.

Day 16: Enrol the pilot group, two or three people, including a sceptic.

Day 17: Run the lost-phone drill. One volunteer pretends to lose a device. Time every step.

Day 18: Run the impersonation test. Have a colleague try to talk the helper into a reset. See what holds.

Day 19: Fix what broke. Update the runbook, the script and the policy.

Week 4: Roll out and tighten

Day 22: Enrol everyone else, in short sessions. Two authenticators each, tested.

Day 23: Switch on passkey sign-in for the identity provider, where your provider offers the option.

Day 24: Remove text-message codes for Tier 1 accounts, and add the second authenticator where missing.

Day 25: Move the long tail into the password manager; turn on passkeys where offered.

Day 26: Run the readiness check again (at the front of the book) and compare.

Day 27: Review the numbers: enrolment, remaining weak sign-ins, helpdesk contacts.

Day 28 to 30: Close the month. Update the inventory, hold a 20-minute staff briefing, diarise the quarterly recovery test and the six-monthly review, and note what you will do in month two.

Month two and beyond

- **Quarterly:** a recovery test and a review of who has what (Appendix F has a tracker).
- **At every hire and departure:** the onboarding and offboarding checklists.

- **Every six months:** re-check which Tier 2 and Tier 3 services now support passkeys; review emergency accounts and keys in the safe.
- **When a provider changes its rules:** read the notice, re-test.
- **When portability improves:** the FIDO Alliance has published draft specifications for moving passkeys between providers; check whether your tools support them before relying on that to simplify recovery.[10]

What "done" looks like

You will know the work has paid off when:

- Every Tier 1 account has two strong authenticators and no text-message fallback.
- Every person can say, in one sentence, what to do if they lose a phone.
- A locked-out person can be let back in, within a few hours, by a procedure an impersonator cannot easily complete.
- Leaving staff can be removed from everything in one working day.
- You have tested all of it, and written down what you learned.

> **The rule.** Thirty days is enough to build a safer, calmer workplace, if you build the recovery first and remove the old ways last.

Conclusion: Passwordless Is a Process

An open lock: the point is to open the door for the right person and nobody else

Return, for a moment, to Ines. Six months after the taxi incident, her agency has a one-page policy, two hardware keys per administrator, a laptop passkey for every person and a drill she runs every quarter. Rui lost his phone again in the spring, this time on a train, and did not even call her until he had already signed in from his laptop and registered a new one.

That is the point of this book. Passkeys remove the most common ways accounts get stolen: the password that can be phished, reused or leaked.[1][2][3] That is a genuine step forward and is worth using. But the result depends on how you run it: which type you choose, how you enrol people, what happens when a phone vanishes, how you share what must be shared, and above all how you let someone back in.

Five habits are worth keeping:

1. **Know what you protect.** Keep the inventory alive.
2. **Register two of everything that matters.** No single loss should lock anyone out.

3. **Give every person their own identity.** Share by delegation, and close accounts, not just devices, when people leave.
4. **Make recovery slower than sign-in and harder than guessing.** Layer it, log it and script it.
5. **Test on purpose.** A recovery you have not tried is a hope.

You do not have to do it all at once, and you do not have to do it perfectly. Start with the five accounts that would hurt most to lose. Put two strong authenticators on each. Write down what you would do if a phone went missing tomorrow. That small beginning already puts you ahead of most businesses of your size.

Then keep going. A workplace that can lose a phone on a Tuesday morning and carry on by lunchtime is not just safer. It is calmer, and that is worth more than any single feature.

APPENDIX A

Account and Sign-In Inventory

One row per account that matters, including free tools. Review it every quarter. Tier: **1** crown jewel, **2** daily tool, **3** long tail. Sign-in today: P password, T text code, A app code, K key, PK passkey, SSO single sign-on.

Service	Tier	Owner / deputy	Who can sign in	Sign-in today	Passkeys?	2+ registered?

Questions to answer for each Tier 1 account

- Which recovery methods exist, and which have we removed?

  _____

- Where are the backup codes or spare key, and who may fetch them?

  _____

- Date we last tested recovery: _____
- If the owner left tomorrow, could we still get in? Yes / No

APPENDIX B

One-Page Passkey Policy

Adapt this to your business. Short beats complete: a policy people read is stronger than a policy people sign.

1. Purpose. To make signing in to business accounts resistant to phishing and recoverable after a lost device.

2. Scope. All people with access to company accounts, including contractors, on company or personal devices.

3. Rules

- Every person has their own account. Shared logins are not allowed, except where an account cannot be delegated and the owner has approved it in the inventory.
- Every Tier 1 and Tier 2 account has **at least two registered authenticators** per person.
- Administrators and finance approvers use **hardware security keys**, two each, one stored securely.
- Text-message codes are not used for Tier 1 accounts.
- Devices have a screen lock (PIN or biometrics) and are kept up to date.
- A lost or stolen device is reported **immediately** to _____.
- Work credentials on personal devices are kept in a work profile where available; the business will manage work accounts only, not personal data.

4. Recovery. Recovery follows Appendix E. No one recovers their own account. Administrators and finance approvers need two approvers.

5. Leaving. On departure, the person's account is disabled the same working day and the checklist in Appendix D is completed.

6. Review. This policy is reviewed every six months and after any incident.

Approved by: _____ Date: _____ Next review: _____

APPENDIX C

Lost or Stolen Phone Runbook

Print this page. Keep a copy somewhere that does not depend on the lost phone.

Reporter: _____ **Time reported:** _____ **Handler:** _____

Minutes 0 to 10

- ☐ Confirm the reporter's identity through a known channel (call back on the recorded number, or ask a colleague).
- ☐ Lock the device remotely (Find My / Find Hub / device-management tool).
- ☐ Ask the mobile network to suspend the SIM if the number is used for any sign-in code.
- ☐ Note: was the phone locked? Was it unlocked when lost? Does it hold work data? _____

Minutes 10 to 30

- ☐ Remove the device from the person's accounts in the identity provider and in their platform account.
- ☐ Revoke active sessions.
- ☐ List what was only on that phone: authenticator apps, passkeys, chats, saved files.
- ☐ Reset or re-register those that matter.

Minutes 30 to 60

- ☐ Does the person have another authenticator? Yes / No
- ☐ If yes, sign in with it and register the new phone.
- ☐ If no, start the recovery procedure (Appendix E).
- ☐ Test the new sign-in and remove the old device.

Decision

Situation	Action
Misplaced, locked, found	Lock remotely, carry on
Lost, locked, not found	Remove and replace
Stolen, or unlocked when lost	Incident: reset exposed accounts, review logs
Administrator or finance approver	Treat as incident

After

- ☐ Review sign-in history for the last _____ days.
- ☐ Decide whether personal data was affected and whether it needs recording or reporting.
- ☐ Write down what slowed us down and update this runbook.

APPENDIX D

Onboarding and Offboarding Checklists

Onboarding

- ☐ Account created with the minimum access for the role
- ☐ Identity verified in person or by video
- ☐ One-time setup code issued, time-limited
- ☐ Two authenticators registered and tested
- ☐ Added to the password manager
- ☐ Added only to the shared accounts needed
- ☐ Lost-phone one-pager given and explained
- ☐ Recorded in the inventory

Role change

- ☐ Access reviewed against the new role
- ☐ Authenticator set reviewed (hardware key needed?)
- ☐ Shared-account ownership transferred where needed

Offboarding

- ☐ Account disabled (not just authenticators removed)
- ☐ Active sessions and app tokens revoked
- ☐ Removed from shared accounts; shared passwords rotated
- ☐ Ownership of files, calendars, lists and accounts transferred
- ☐ Individually listed authenticators removed from accounts
- ☐ Company devices and security keys returned
- ☐ Removed from the password manager
- ☐ Email handled under the retention policy
- ☐ Date and actions recorded

Person: _____ Date: _____ Done by: _____
Checked by: _____

APPENDIX E

Recovery Register and Helpdesk Script

Part 1: Recovery methods register. For each Tier 1 account, list every way back in, and mark any to remove.

Account	Method	Strength	Keep / remove	Notes

Part 2: Helpdesk script. Read from the page. Do not improvise.

1. Say: "I need to follow our recovery procedure. It applies to everyone."
2. Ask which account and what they have lost. Note the time.
3. Do **not** act on the request yet.
4. Verify with **two** independent checks:
   - Check one: _____ (for example, a call back on the number on file)
   - Check two: _____ (for example, a video call with a second person present)
5. For an administrator or finance approver, obtain approval from a **second approver** who has not been on the original call.
6. Issue a **single-use, time-limited** setup code (expires in _____ hours) to be used on a device the person controls.
7. Notify the person's other contact address and the second approver that a recovery was issued.

8. After the person has registered a new authenticator, remove the old one and any method that was weak.
9. Log: who asked, who verified, which checks, what was issued, time.

If anything feels wrong: stop, say "I will call you back", and escalate to _____.

Part 3: Break-glass accounts

Account	Location of key 1	Location of key 2	Who may authorise use	Last test

APPENDIX F

30-Day Rollout Tracker

Tick each task as it is done. Add the date.

Week 1: Know

- ☐ Day 1: scope and one-sentence purpose _____
- ☐ Day 2: inventory filled in (Appendix A) _____
- ☐ Day 3: accounts tiered _____
- ☐ Day 4: owners and deputies named _____
- ☐ Day 5: passkey home chosen per person _____

Week 2: Prepare

- ☐ Day 8: types chosen; hardware keys ordered _____
- ☐ Day 9: policy drafted (Appendix B) _____
- ☐ Day 10: recovery designed (Appendix E) _____
- ☐ Day 11: two break-glass accounts set up _____
- ☐ Day 12: lost-phone runbook adapted (Appendix C) _____

Week 3: Pilot

- ☐ Day 15: administrators enrolled with two authenticators _____
- ☐ Day 16: pilot group enrolled _____
- ☐ Day 17: lost-phone drill run and timed _____
- ☐ Day 18: impersonation test run _____
- ☐ Day 19: fixes made to runbook and script _____

Week 4: Roll out and tighten

- ☐ Day 22: everyone enrolled with two authenticators _____
- ☐ Day 23: passkey sign-in switched on for the identity provider _____
- ☐ Day 24: text-message codes removed from Tier 1 _____
- ☐ Day 25: long tail in the password manager _____

- ☐ Day 26: readiness check repeated; score _____
- ☐ Day 27: numbers reviewed _____
- ☐ Day 28 to 30: briefing held; quarterly test diarised _____

Numbers at the end

Measure	Start	Day 30
People with two or more authenticators		
Tier 1 accounts with passkeys on		
Tier 1 accounts still allowing text codes		
Sign-in helpdesk requests that week		

Glossary

Account recovery. The process that lets a person back in to an account when they have lost their usual way of signing in.

Attestation. An optional statement, made when a passkey is created, about what kind of authenticator created it.

Authenticator. Anything that proves you are you: a phone, a laptop, a security key.

Break-glass account. An emergency administrator account, protected offline, used only when normal access has failed.

Cross-device sign-in. Using a phone to sign in on another computer by scanning a QR code, with a proximity check, so nothing stays on the computer.

Device-bound passkey. A passkey that lives on one device or security key and cannot be copied or synced.

Downgrade attack. An attack that avoids a strong sign-in by choosing a weaker fallback, such as a text code or emailed link.

FIDO Alliance. The industry group that defines the standards behind passkeys.

Identity provider. The service that holds your sign-ins for many applications, such as a workplace suite.

Passkey. A credential made of a private key held on your device and a public key held by the service, used to sign in without a password.

Phishing-resistant. Designed so that a fake site cannot capture something an attacker can reuse on the real one.

Private key / public key. The two halves of a key pair. The private half stays with you; the public half goes to the service.

Relying party. The service that asks you to sign in, in standards language.

Security key. A small physical device that holds passkeys and cannot be copied.

Session. The signed-in state after you have authenticated, usually held by a token in your browser or app.

Synced passkey. A passkey stored in a cloud account and copied to a person's other devices.

WebAuthn. The web standard that lets websites request passkey sign-in.

A Note on GDPRGard.eu

If your work with passkeys touches customer data, the free tools, guides and articles at **gdprgard.eu** can help you with the surrounding data-protection tasks: records of processing, breach response and policies. They are a companion resource, not a substitute for advice on your own situation.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, cyber-security, AI and building a business with confidence. She believes technology should give small businesses more control, not less, and that nobody should need a technical degree to understand their rights or protect their customers.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex rules and fast-moving technology into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Passkeys at Work grew out of a simple observation: businesses adopt stronger sign-in and almost never plan for the morning someone loses a phone. If this guide helped you, an honest review where you bought it helps other readers find it.

Visit **gdprgard.eu** for free tools, articles and updates.

Notes and Sources

Research cut-off: 12 November 2026. Items marked (read) were opened directly; others were seen through search summaries or secondary coverage, or rest on the author's working knowledge, and should be checked against the original before you rely on them.

1. W3C, Web Authentication (WebAuthn) specification: public-key credentials scoped to a relying party identifier, with origin checking by the user agent; and the FIDO2 / CTAP specifications of the FIDO Alliance (working knowledge; read the current specification text).
2. FIDO Alliance, overview of passkeys: discoverable credentials, per-site key pairs, local user verification; biometric data does not leave the device in the standard design (working knowledge; check the FIDO Alliance pages).
3. US Cybersecurity and Infrastructure Security Agency, fact sheet "Implementing Phishing-Resistant MFA", October 2022: describes FIDO/WebAuthn as the main widely available phishing-resistant authentication, with PKI-based authentication as a second option (seen through search summaries and secondary coverage; the PDF was not read in full).
4. FIDO Alliance, Passkey Index (published 13 October 2025): participants reported a 93 percent sign-in success rate for passkeys against 63 percent for other methods; based on a small group of large FIDO member organisations. A later edition exists and was not read (search summaries only).
5. Google, Workspace Admin and Account help pages on passkeys, and Google Workspace announcements: admins can allow users to skip passwords with passkeys (off by default); passkeys can be used as a second factor and for recovery even when off; July 2025 general availability with audit and security-key restriction controls (search summaries; menu paths not checked).
6. Microsoft Learn and secondary analysis on Microsoft Entra ID passkeys: passkey profiles, device-bound versus synced passkeys, recommendation of device-bound for privileged users, attestation limits for synced passkeys, Temporary Access Pass for onboarding, and identity-verified recovery; also Microsoft's emergency access account guidance (working knowledge and secondary summaries; Microsoft Learn pages were not read directly, and the rollout dates should be checked).
7. Apple platform support and security documentation on passkeys: synchronisation through iCloud Keychain, end-to-end encryption, recovery via a recovery contact or iCloud Keychain escrow (search summaries of Apple

support pages). Google Password Manager, Microsoft and several third-party password managers also sync or store passkeys (working knowledge).

8. Regulation (EU) 2016/679 (GDPR), Articles 5, 9, 25, 32 and 33: biometric data used for unique identification is special-category data; whether and how your own set-up processes it depends on your devices and providers (working knowledge; read the text and the provider's documentation).
9. National Institute of Standards and Technology, SP 800-63B-4 (Digital Identity Guidelines, Authentication and Authenticator Management, 2025) and its syncable-authenticator guidance: syncable authenticators permitted at AAL2 under conditions; not permitted at AAL3 (search summaries and secondary analysis; the final text was not read).
10. FIDO Alliance, Credential Exchange Protocol (CXP) and Credential Exchange Format (CXF) working drafts for moving passkeys between providers, first published October 2024 (search summaries; current status and provider adoption were not confirmed).

Not verified by the author: the exact menus, defaults and limits of any named provider today; Microsoft's automatic enablement dates for passkey profiles; Google Workspace's current admin paths; whether any provider limits the number of passkeys per account in a way that affects Chapter 6; the text of NIST SP 800-63B-4; the current status of FIDO credential-exchange specifications; and the current prices of hardware security keys. Pricing statements in the book ("tens of euros") are an estimate. Ines, Rui, Luka, Mara and their businesses, and all events in the worked examples, are fictional.